

SVEACARE

Säkerhetsarkitektur & Resiliens

Fiktivt portfolio-case

Att designa en säker och motståndskraftig vårdmiljö. Från verksamhetens behov och risker till målarkitektur, implementation och validering.

Sammanfattning

Denna sida ger en snabb överblick. Fullständig analys, motivering och bevisföring finns i resterande avsnitt.

SveaCare är en fiktiv vårdorganisation som hanterar mycket känslig patientinformation via kliniska applikationer, diagnostiksystem, identitetstjänster, databaser, backupinfrastruktur och tredjepartsintegrationer. Den centrala arkitekturfrågan är hur systemen kan förbli tillräckligt sammankopplade för att stödja vården, utan att ett enskilt komprometterat konto eller system kan slå ut hela miljön.

Designprincip

Zero Trust: ingen användare, enhet eller tjänst litas på automatiskt bara för att den befinner sig innanför nätverksperimetern, varje åtkomst verifieras explicit.

De tre viktigaste besluten

Separata privilegierade konton: administrativt arbete isoleras från vardagligt användararbete (ADR-001).

Nätverkssegmentering i zoner (applikation, data, admin, logg, backup) för att begränsa lateral förflyttning (ADR-003).

Isolerad och oföränderlig backup, separerad administrativt från produktion, så en angripare inte kan förstöra både produktion och återställningskopior samtidigt (ADR-004).

Förväntad effekt

Stärkt identitets-, nätverks-, applikations- och datasäkerhet, förbättrad operativ resiliens och detektionsförmåga, samt spårbarhet från risk och krav till beslut och validering.

Utmaningen

SveaCare är en fiktiv vårdorganisation som hanterar mycket känslig patientinformation. Verksamheten är beroende av flera sammankopplade system, bland annat kliniska applikationer, diagnostiksystem, identitetstjänster, databaser, backupinfrastruktur och integrationer mot tredje part.

Utmaningen var att utforma en arkitektur som stärker skyddet av:

Konfidentialitet: Obehöriga får inte komma åt patientdata.

Integritet: Information får inte manipuleras utan behörighet.

Tillgänglighet: Kritiska vårdtjänster måste förbli tillgängliga.

Spårbarhet: Viktiga händelser måste gå att utredas i efterhand.

Den viktigaste arkitekturfrågan blev:

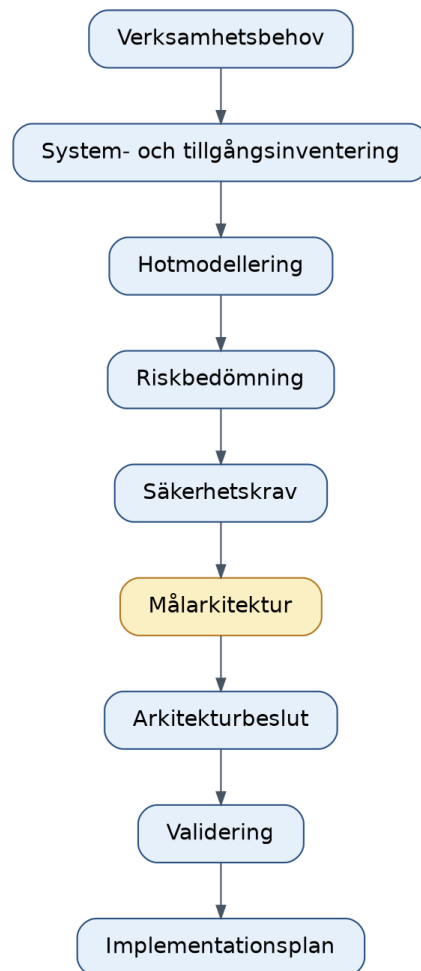
Hur kan system förbli tillräckligt sammankopplade för att stödja vårdverksamheten, utan att ett enda komprometterat konto eller system kan slå ut hela miljön?

Som vårdaktör behöver SveaCare förhålla sig till flera regelverk och kravområden, bland annat Patientdatalagen (PDL), GDPR och NIS2 där organisationen omfattas av tillämpliga krav.

I detta case används regelverken som utgångspunkt för krav på bland annat informationssäkerhet, spårbarhet, riskhantering och incidenthantering. Exakt juridisk tillämplighet skulle verifieras mot organisationens verksamhet och aktuella regelverk i en verklig implementering.

Mitt angreppssätt

Jag angrep problemet som ett arkitekturprojekt snarare än att utgå från specifika säkerhetsprodukter, med ett arbetssätt inspirerat av etablerade ramverk som TOGAF (arkitekturprocess) och SABSA (att härleda arkitektur ur verksamhetens risk och krav, lager för lager)



Det gjorde det möjligt att koppla varje större teknisk lösning till ett identifierat verksamhets- eller säkerhetskrav.

Den övergripande designprincipen är Zero Trust: Ingen användare, enhet eller tjänst litas på per automatik enbart för att den befinner sig innanför nätverksperimetern, varje åtkomst verifieras explicit, oavsett var den kommer ifrån.

Nuläge & Gap-analys

Innan målarkitekturen kunde definieras kartlades SveaCares antagna nuläge, för att identifiera var de största gapen mot en säker och motståndskraftig miljö låg.

Observera: nuläget är antaget och inte verifierat.

Område	Antaget nuläge	Identifierat gap
Autentisering	Lösenord + delvis MFA	MFA saknas för vissa administrativa konton
Nätverk	Platt nätverk med begränsad segmentering	Ingen zonindelning mellan användare, data och backup
Backup	Backup i samma administrativa domän som produktion	Ingen isolering, sårbart för ransomware
Loggning	Loggar finns per system, ej centraliserade	Svårt att rekonstruera händelsekedjor
Behörigheter	Breda, ackumulerade rättigheter över tid	Bryter mot least privilege

Gap-analysen används som grund för prioriteringen i implementationsplanen. Insatser riktas först mot områden där gapet mot målarkitekturen är stort och risknivån bedöms som hög.

Styrning & intressenter

Säkerhetsarkitektur är inte enbart en teknisk fråga. Beslut måste förankras hos rätt roller för att faktiskt bli av och hållas över tid.

CISO

Äger den övergripande säkerhetsrisken

Dataskyddsombud (DPO)

Ansvarar för GDPR-efterlevnad

Klinisk säkerhetsansvarig

Bedömer patientsäkerhetskONSEKVENSER

IT-drift

Förvaltar och implementerar kontroller löpande

Arkitekt (min roll)

Föreslår, motiverar och avväger lösningen mellan dessa intressen

Varje ADR i avsnitt 15 är skriven för att kunna föredras för denna grupp. Beslutet, motivet och konsekvensen ska gå att förstå utan djup teknisk bakgrund.

Centrala risker

Hotmodelleringen utgick från STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) för att systematiskt identifiera hotkategorier per systemkomponent, kompletterat med resonemang kring kända angreppsmönster i linje med MITRE ATT&CK för de tekniska scenarierna (t.ex. lateral förflyttning, privilegie eskalering). Analysen identifierade flera scenarier med hög påverkan.

Komprometterade autentiseringsuppgifter

En angripare kommer över en legitim användares inloggningsuppgifter.

Potentiell påverkan: Obehörig åtkomst och lateral förflyttning i nätverket.

Komprometterat privilegierat konto

En angripare får administrativa rättigheter.

Potentiell påverkan: Omfattande kompromettering av system.

Utpressningstrojaner (ransomware)

Produktionssystem och data blir otillgängliga.

Potentiell påverkan: Störningar i kritisk vårdverksamhet.

Manipulation av data

Patientinformation ändras.

Potentiell påverkan: Felaktiga kliniska beslut.

Radering av data

Information tas bort avsiktligt eller av misstag.

Potentiell påverkan: Förlust av kritisk patientinformation.

Kompromettering via tredje part

En extern integration blir en attackväg.

Potentiell påverkan: Kompromettering av anslutna interna system.

Riskmatris

Prioritet bedöms som sannolikhet × konsekvens, enligt en enkel 3x3-modell:

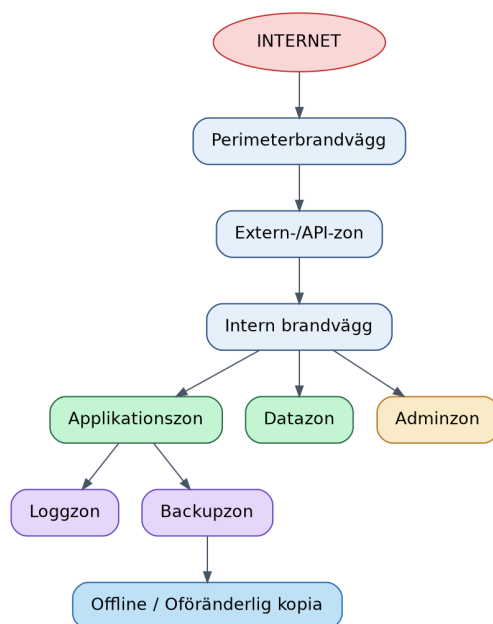
Konsekvens \ Sannolikhet	Låg	Medel	Hög
Kritisk	Hög	Kritisk	Kritisk
Betydande	Medel	Hög	Kritisk
Begränsad	Låg	Medel	Hög

Risk	Sannolikhet	Konsekvens	Prioritet
Komprometterade autentiseringsuppgifter	Hög	Betydande	Kritisk
Komprometterat privilegierat konto	Medel	Kritisk	Kritisk
Ransomware	Medel	Kritisk	Kritisk
Manipulation av data	Låg	Kritisk	Hög
Radering av data	Medel	Betydande	Hög
Kompromettering via tredje part	Medel	Betydande	Hög

Matrisen gör riskprioriteringen granskningsbar: varje risks placering kan spåras till en explicit bedömning av sannolikhet och konsekvens, snarare än en subjektiv känsla.

Målarkitektur

Arkitekturen bygger på djupledsförsvär (defense in depth).



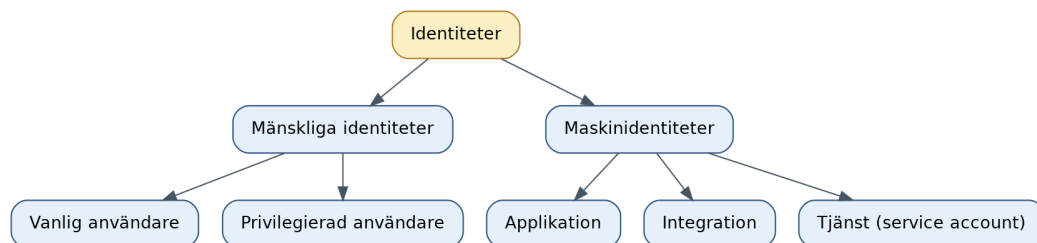
Arkitekturprinciper

- Åtkomst nekas som standard och tillåts endast när den är explicit definierad.
- Nätverksplacering ska inte i sig ge förtroende eller behörighet.
- Kommunikation mellan zoner ska vara begränsad till identifierade verksamhetsbehov.
- Ett komprometterat konto eller system ska inte automatiskt ge åtkomst till hela miljön.

Målet är att begränsa blast radius och samtidigt behålla den kommunikation som verksamheten behöver.

Identitet & åtkomst

Identiteter delas upp i tre kategorier.



Mänskliga och maskinbaserade identiteter hanteras separat eftersom deras livscykler, risker och åtkomstbehov skiljer sig åt. Privilegierad åtkomst separeras från normalt användararbete för att minska konsekvensen av ett komprometterat användarkonto.

I en verklig miljö behöver modellen kompletteras med livscykelhantering, behörighetsrecertifiering och processer för att snabbt avaktivera identiteter.

Exempel: Vanliga användare har individuella konton med MFA och rollbaserade behörigheter (anna.svensson). Privilegierade administratörer har separata administrativa konton med starkare autentisering och utökad övervakning (adm-anna.svensson). Maskinidentiteter autentiserar sig mot andra system med egna, dedikerade identiteter i stället för mänskliga autentiseringsuppgifter.

Auktorisering

Autentisering svarar på frågan: Vem är du?

Auktorisering svarar på frågan: Vad har du rätt att göra?

Arkitekturen använder därför kedjan:

Identitet → Autentisering → Auktorisering → Åtgärd

RBAC används som grundmodell, men åtkomst ska alltid bedömas utifrån det faktiska behovet. En roll ska därför inte automatiskt innebära tillgång till all information eller alla funktioner inom ett system. Vid behov kan ytterligare kontext behöva vägas in, exempelvis

system, funktion, informationstyp eller aktuell situation. Varje integration ska ha en definierad ägare och ett dokumenterat syfte.

Läkare: Kliniska funktioner.

Sjuksköterska: Kliniska funktioner.

Administrativ användare: Administrativa funktioner.

Säkerhetsadministratör: Säkerhetsadministration.

Behörigheter baseras på principen om lägsta privilegium (least privilege) och behovsstyrd åtkomst (need-to-know).

Systemintegration

Vilka system behöver egentligen kommunicera med varandra?

I stället för att anta att system ska kunna kommunicera fritt får varje integration en explicit definition: källa, mål, protokoll, port, data, autentisering, auktorisering, kryptering, verksamhetssyfte och ägare.

Exempel: SveaCare kan vara auktoriserat att skicka en specifik klinisk transaktion (autentiserad, krypterad) till röntgensystemet, utan att för den skull få administrativ åtkomst till hela röntgenmiljön.

Nätverkssegmentering

Arkitekturen är utformad för att minska risken att en komprometterad arbetsstation kan användas som direkt väg till kritisk infrastruktur. Segmentering är dock inte en ensam säkerhetskontroll, den kombineras med autentisering, auktorisering och övervakning för att begränsa konsekvenserna av en kompromettering.

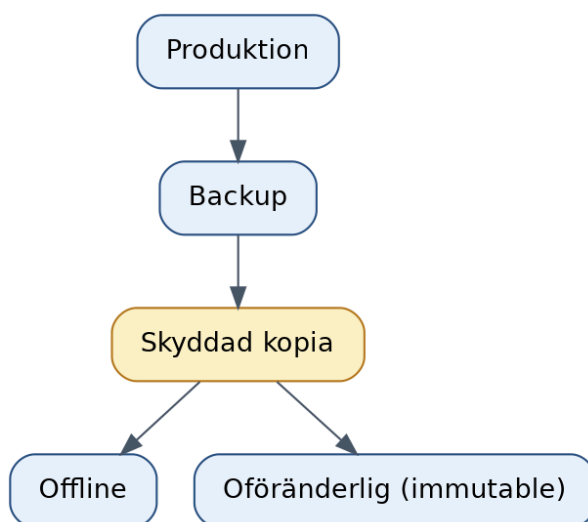
Från	Till	Tillåten?
Användarnätverk	Databas	Nekad
Användarnätverk	Backup	Nekad
SveaCare	Röntgen	Tillåten (specifik transaktion)

Detta minskar den potentiella skadeytan (blast radius) vid en kompromettering. Nätverkssegmentering kombineras med autentisering och auktorisering, snarare än att användas som en fristående säkerhetsmekanism.

Backup & resiliens

En backup är bara användbar om en angripare inte kan förstöra backupen tillsammans med produktionsmiljön.

Den föreslagna designen separerar därför backupinfrastrukturen från den vanliga produktionsadministrationen.



RTO / RPO

Backupdesignen bedöms inte enbart utifrån hur data kopieras, utan utifrån om verksamheten faktiskt kan återställa kritiska tjänster inom definierade tidsramar. Exempel på målvärden per systemklass:

Systemklass	Exempel	RTO (max avbrott)	RPO (max dataförlust)
Kritiska kliniska system	Journalsystem, läkemedelsordination	4 timmar	15 minuter
Viktiga stödsystem	Diagnostiksystem, schemaläggning	24 timmar	4 timmar
Administrativa system	Rapportering, intern portal	72 timmar	24 timmar

Dessa målvärden är exempel för portfolio-caset och skulle i en verklig implementation fastställas tillsammans med klinisk verksamhet och verksamhetsägare. Därför är återställningstest en del av arkitekturen, inte en aktivitet som lämnas till slutet av implementationen.

Backupadministration kräver: Separata identiteter, stark MFA, mycket begränsad åtkomst, loggning och återkommande behörighetsgranskning. Viktigast av allt: återställning måste testas, inte bara antas fungera.

Arkitekturprincip: produktionsmiljön ska inte ha tillräckliga administrativa rättigheter för att ensam kunna förstöra både produktion och återställningskopior. Återställningsförmågan ska ha separerade administrativa gränser och testas regelbundet.

Loggning & utredning

Vem gjorde vad, när och varifrån?

Arkitekturen korrelerar flera källor: identitetsloggar, brandväggsloggar, applikationsloggar, endpoint-loggar och granskningsloggar (audit logs) till en samlad händelsekedja (incident timeline).

Tid	Händelse	Resultat
08:41	Inloggning	LYCKADES
08:43	Patientjournal öppnad	LYCKADES
08:44	Administrativ åtgärd	NEKAD
08:46	Ny autentisering	LYCKADES
08:47	Avvikande åtkomst	LARM

Det gör det möjligt för utredare att rekonstruera händelseförlopp i stället för att bara titta på en enskild logg i taget. Loggning är inte ett mål i sig: Loggarna behöver vara tillräckliga för de utredningsfrågor verksamheten och säkerhetsfunktionen behöver kunna besvara, och de behöver skyddas mot obehörig förändring.

Incidenthantering



Arkitekturen stödjer specifikt utredning av komprometterade konton, manipulerad information, utpressningstrojaner, obehörig åtkomst, misstänkta systemintegrationer och lateral förflyttning.

En viktig princip är att skilja mellan den identitet som användes och den faktiska person som var ansvarig: Att ett konto används bevisar inte i sig vem som utförde handlingen. Arkitekturen behöver därför stödja både teknisk spårbarhet och den organisatoriska incidentprocess som krävs för att tolka och hantera informationen.

Validering

Arkitekturen anses inte lyckad enbart för att diagrammet ser bra ut. Den måste testas.

Test	Förväntat resultat	Bevis
Användare försöker kringgå MFA	Nekad	Autentiseringslogg
Vanlig användare utför administrativ åtgärd	Nekad	Audit-logg
Användarnätverk försöker nå databas	Nekad	Brandväggslogg
Ogiltig systemidentitet försöker nå röntgen	Nekad	API-/systemlogg
Obehörig användare försöker ändra loggar	Nekad	Granskningslogg (immutable audit log)
Auktoriserad integration når röntgen	Tillåten	Integrations-/API-logg
Kritisk backup återställs	Lyckad	Återställningsrapport
Produktionskonto försöker administrera backup	Nekad	Backupsystemets åtkomstlogg

Krav → Arkitektur → Implementation → Test → Bevis (evidence)

Arkitekturbeslut (ADR)

Flera viktiga beslut dokumenterades som Architecture Decision Records.

ADR-001. *Separata privilegierade konton*: Minskar effekten av ett komprometterat vanligt konto.

ADR-002. *Rollbaserad åtkomstkontroll (RBAC)*: Ger en skalbar och granskningsbar auktoriseringsmodell.

ADR-003. *Nätverkssegmentering*: Begränsar lateral förflyttning och minskar skadeytan.

ADR-004. *Isolerad och motståndskraftig backup*: Skyddar återställningsförmågan från kompromettering i produktion.

ADR-005. *Autentiseringsarkitektur*: Separerar mänsklig autentisering från maskin-till-maskin-autentisering.

ADR-004 i fullt format (exempel)

Nedan visas ADR-004 i fullständigt format, som exempel på hur samtliga beslut dokumenterades i det underliggande arbetet.

Fält	Innehåll
Titel	Isolerad och motståndskraftig backup
Status	Beslutad
Kontext	Backup låg i samma administrativa domän som produktion (se Nuläge & Gap-analys). En angripare som fick administrativa rättigheter i produktionsmiljön kunde därmed i teorin även förstöra eller kryptera backup kopiorna, vilket gör ransomware till en kritisk risk (se Centrala risker) och undergräver hela syftet med att ha backup.
Övervägda alternativ	1. Behålla gemensam administrativ domän men öka loggning och larm. 2. Separat backup-domän med egna identiteter, men utan oföränderlig lagring. 3. Separat backup-domän med egna identiteter samt offline-/oföränderlig kopia.
Beslut	Alternativ 3: Backup-infrastrukturen separeras administrativt från produktion, med egna identiteter, stark MFA och mycket begränsad åtkomst. Skyddade kopior hålls offline eller oföränderliga (immutable).
Konsekvenser	Positivt: Ett komprometterat produktionskonto kan inte längre ensamt förstöra både produktion och återställningskopior, vilket direkt begränsar blast radius vid ransomware. Negativt: kräver egen administrativ process, egna identiteter och regelbundna återställningstester, vilket ökar driftkomplexiteten och kräver dedikerad budget (se Mätetal & resurser).

Implementationsplan

Tidsplanen är en principiell roadmap för portfolio-caset. Faktisk genomförandetid behöver baseras på organisationens storlek, teknisk skuld, beroenden, förändringsförmåga och tillgängliga resurser.

Fas	Period	Aktiviteter
1. Kartlägg	0–2 månader	Fullständig systeminventering, kartlägg integrationer, identifiera kritisk information och privilegierade konton, dokumentera nätverk och backup-förmåga.
2. Skydda	2–4 månader	Inför MFA, separera privilegierade konton, implementera RBAC, ta bort onödiga behörigheter, segmentera kritiska system, begränsa administrativ åtkomst.
3. Resiliens	4–8 månader	Isolera backup-infrastrukturen, implementera skyddade återställningskopior, förbättra centraliserad loggning och övervakning, testa återställningsrutiner.
4. Validera & förbättra	8–12 månader	Säkerhetstestning, återställningsövningar, incidentsimuleringar, granskningar från tredje part, behörighets- och arkitekturgranskning.

Mätetal & resurser

Andel identifierade privilegierade konton under formell PAM-hantering (mål: 100 % efter fas 2).

MTTD (mean time to detect) och MTTR (mean time to respond) för säkerhetsincidenter.

Andel kritiska system med testad, lyckad återställning (mål: 100 % efter fas 3).

Antal öppna, ej riskbedömda tredjepartsintegrationer (mål: 0 efter fas 4).

Roadmapen förutsätter avsatt budget för framför allt PAM-lösning, centraliserad loggning/SIEM samt oföränderlig backup-lagring, de tre områden där gapet i Nuläge & Gap-analys var störst.

Viktiga avvägningar

God arkitektur handlar inte om att eliminera all risk. Det handlar om att göra medvetna avvägningar.

Säkerhet vs. användbarhet

Mer MFA och striktare kontroller ökar säkerheten, men kan skapa friktion för klinisk personal.

Isolering vs. integration

Mer segmentering förbättrar säkerheten men gör integrationer mer komplexa.

Tillgänglighet vs. säkerhet

Alltför aggressiva säkerhetskontroller kan i sig påverka tillgängligheten om de implementeras fel.

Kostnad vs. resiliens

Offline-/oföränderlig backup ger starkare återställningsförmåga men kräver extra infrastruktur och driftinsats.

Arkitekturen strävar därför efter lämplig säkerhet, inte maximal säkerhet till varje pris.

Exempel på arkitekturell avvägning

Om MFA införs för all privilegierad åtkomst ökar skyddet mot komprometterade administratörskonton. Samtidigt kan striktare autentisering skapa problem vid tidskritiska situationer. Arkitekturbeslutet behöver därför ta hänsyn till både säkerhetsnivå och verksamhetens krav på tillgänglighet. Eventuella undantag ska vara begränsade, dokumenterade och kompenseras med andra kontroller.

Vad som måste verifieras i en verklig miljö

Det här caset skiljer medvetet mellan arkitekturbeslut och overifierade antaganden. I en verklig implementation skulle jag först verifiera:

Befintliga system och integrationer

Autentiseringsmetoder, brandväggsregler, nätverkszoner, VPN, MFA

Tjänstekonton (service accounts)

Backup-arkitektur, loggning

Åtkomst för tredje part

RTO/RPO och befintliga säkerhetskontroller

Jag skulle inte anta att en kontroll finns bara för att arkitekturen rekommenderar den.

Förväntad effekt av målarkitekturen

Identitetssäkerhet: Stärka autentisering och kontroll över privilegier.

Nätverkssäkerhet: Begränsa kommunikationsvägar och lateral förflyttning.

Applikationssäkerhet: Stödja autentiserade och auktoriserade integrationer.

Datasäkerhet: Minska risken för obehörig åtkomst och manipulation.

Operativ resiliens: Stärka möjligheten att återställa kritiska tjänster.

Detektion: Förbättra möjligheten att upptäcka och utreda incidenter.

Governance: Skapa spårbarhet från risk och krav till beslut och validering.

Effekten behöver verifieras genom implementering, tester och uppföljning.

Vad detta case visar

Projektet visar min förmåga att arbeta genom hela arkitekturens livscykel:

Problem → analys → risk → krav → arkitektur → beslut → implementationsplanering → validering → styrning.

I stället för att välja teknik först utgår jag från verksamhetsproblemet, riskerna och kraven och använder därefter arkitektur för att lösa dem.

Reflektion

Den viktigaste lärdomen från projektet är att säkerhetsarkitektur inte bara handlar om att lägga till fler säkerhetskontroller. En stark arkitektur måste kunna svara på:

Vad skyddar vi?

Vad kan gå fel?

Vad behöver kommunicera?

Vem får göra vad?

Hur vet vi att kontrollerna fungerar?

Vad händer när kontrollerna fallerar?

Det perspektivet är det som binder samman säkerhetsarkitektur, verksamhetsarkitektur, infrastruktur, drift och verksamhetens krav.

Projektleveranser

Kategori	Leveranser
Arkitektur	Målarkitektur, nätverkssegmentering, identitetsarkitektur, integrationsmodell
Analys	Hotmodell (STRIDE, med inslag av MITRE ATT&CK), riskregister med riskmatris, säkerhetskrav
Beslut	5 Architecture Decision Records
Resiliens	Backuparkitektur, återställningsstrategi med RTO/RPO, incidenthantering
Validering	Säkerhetstestplan, återställningstest, spårbarhetsmatris
Implementation	Principiell 12-månaders färdplan med mätetal

SveaCare

Att designa en säker och motståndskraftig vårdarkitektur, från verksamhetsrisk och krav till målarkitektur, beslut och validering.